Nestara AI Security Audit & Vulnerability Report

Code-Level Inspection of REST Endpoints, Access Control, Data Leakage Vectors & Integrity Defects

Target System: Nestara AI Edge API (Hono / Cloudflare Workers)	**Audit Date:** October 27, 2026
Repository: rootnode-rebels/nestara-ai (main branch)	**Overall Security Posture:** CRITICAL RISK
Evaluation Scope: 43 REST Endpoints, Database Queries, RBAC & Auth	**Compliance Standard:** Vibe Coded App Security Checklist

Executive Summary

An in-depth security architecture audit was conducted on the cloned **Nestara AI** codebase to identify endpoint errors, broken access controls, and data leakage channels. The assessment uncovered **6 distinct data leakage channels** and **5 endpoint logic/integrity defects**. Specifically, unauthenticated endpoints leak prospective tenant PII (including monthly income and phone numbers) and complete facility work orders. In addition, a misconfigured CORS policy with reflected origins and ambient credentials allows cross-site data theft, while unrestricted public self-registration allows any internet user to promote themselves to 'landlord' over the entire property portfolio. Immediate hotfixes are detailed herein to remediate all vulnerabilities prior to any production deployment.

6	5	3	4	4
DATA LEAKS FOUND	ENDPOINT LOGIC BUGS	CRITICAL SEVERITY	HIGH SEVERITY	MEDIUM SEVERITY

Auditor Verdict & Immediate Action Requirement:
The repository is currently unsafe for multi-tenant or public cloud deployment without patching. Because database queries currently lack tenant isolation and the authorization middleware omits multiple read routes, attackers can scrape confidential business and personal data trivially without credentials.

Vulnerability & Defect Summary Matrix

The following matrix summarizes all 11 security findings and logic defects discovered across the Nestara AI backend. Severity ratings are evaluated using Common Vulnerability Scoring System (CVSS) principles based on exploitability, privilege requirements, and data impact.

ID	Severity	Endpoint / Component	Category	Vulnerability Title
SEC-01	**CRITICAL**	`GET /api/applications`	PII Data Leak	Unauthenticated Applicant PII & Financial Exposure
SEC-02	**HIGH**	`GET /api/work-orders`	Data Leak	Public Operational & Tenant Maintenance Records Exposure
SEC-03	**HIGH**	`GET /api/dashboard/summary`	Data Leak	Unauthenticated Portfolio Financials & Lease Expiration Disclosure
SEC-04	**CRITICAL**	`/api/* (CORS Configuration)`	Access Control	Permissive CORS with Wildcard Reflection & Ambient Credentials
SEC-05	**CRITICAL**	`POST /api/auth/register`	IDOR / Auth	Untrusted Frontend Tenant ID Assignment & Account Hijacking
SEC-06	**HIGH**	`POST /api/auth/register`	Privilege Escalation	Unrestricted Public Self-Registration as Portfolio Landlord
BUG-01	**MEDIUM**	`POST /api/rent-charges/generate`	Logic Defect	Missing Start-Date Window Boundary Generating Premature Charges
BUG-02	**MEDIUM**	`POST /api/payments`	Integrity Defect	Orphaned Payment Records via Pre-Validation Database Insertion
BUG-03	**MEDIUM**	`POST /api/tenants & /leases`	Logic Defect	Silent Demotion of Admin/Landlord Accounts on Tenant Provisioning
BUG-04	**MEDIUM**	`Global Error Handling`	Error Boundary	Missing app.onError Exposing Internal Engine Stack Traces
BUG-05	**LOW**	`POST /api/ai/recommend & /compare`	DoS Vector	Missing Sliding-Window Rate Limiting on Vector AI Pipelines

Impact Categorization:
• **CRITICAL:** Direct vulnerability leading to complete identity takeover, unauthorized access to applicant financials, or cross-origin session hijacking without user interaction.
• **HIGH:** Exposure of internal operational databases, unauthenticated access to tenant maintenance logs, or self-elevation to portfolio manager.
• **MEDIUM:** Business logic flaws leading to billing inaccuracy, orphaned database records, or unauthorized account attribute alterations.
• **LOW:** Unthrottled computational endpoints susceptible to resource exhaustion.

Section 1: Detailed Data Leakage Findings

[CRITICAL] SEC-01: Unauthenticated Applicant PII & Financial Exposure

CWE: CWE-200 / CWE-284

Target Endpoint: `GET /api/applications`
Source Location: `src/server/index.ts (Lines 1385-1394)`

Root Cause Analysis:
The route protection middleware in src/server/index.ts guards mutating HTTP verbs (POST, PUT, DELETE) and specific paths (/api/tenants, /api/leases, /api/rent-charges, /api/payments). **GET /api/applications was completely omitted** from the protected read list.

Data Leaked / Threat Vector:
Any anonymous user on the public internet can send a GET request to /api/applications and retrieve the entire database of applicant records, including **full names, personal email addresses, phone numbers, monthly salaries, employers, and background notes**.

Required Remediation:
Add path.startsWith('/api/applications') to the requireRoles('landlord', 'admin') check in the route authorization middleware.

[HIGH] SEC-02: Public Operational & Tenant Maintenance Records Exposure

CWE: CWE-200 / CWE-284

Target Endpoint: `GET /api/work-orders`
Source Location: `src/server/index.ts (Lines 1315-1327)`

Root Cause Analysis:
Similar to SEC-01, /api/work-orders was excluded from the middleware read-protection whitelist. Only mutation requests were restricted to authenticated landlords.

Data Leaked / Threat Vector:
Anonymous visitors can query all building maintenance tickets, leaking **tenant first and last names, unit and property identifiers, descriptions of property damage, vendor contact names, and associated repair costs**.

Required Remediation:
Require requireRoles('landlord', 'admin') for GET /api/work-orders. Individual residents should access only their own tickets strictly through GET /api/tenant/portal.

[HIGH] SEC-03: Unauthenticated Portfolio Financials & Lease Expiration Disclosure

CWE: CWE-200 / CWE-284

Target Endpoint: `GET /api/dashboard/summary`
Source Location: `src/server/index.ts (Lines 1620-1713)`

Root Cause Analysis:
The dashboard analytics endpoint has zero authentication or role checks applied, serving internal operational intelligence to any caller.

Data Leaked / Threat Vector:
Exposes sensitive commercial data: **total rent collected, total outstanding debt, overdue rent amounts, occupancy rates, and upcoming lease terminations** including tenant names and unit locations.

Required Remediation:
Apply requireRoles('landlord', 'admin') to GET /api/dashboard/summary.

[CRITICAL] SEC-04: Permissive CORS with Wildcard Reflection & Ambient Credentials

CWE: CWE-942 (Permissive CORS Policy)

Target Endpoint: `/api/* (Global Middleware)`
Source Location: `src/server/index.ts (Lines 20-26)`

Root Cause Analysis:
The CORS middleware uses dynamic origin reflection: origin: (origin) => origin || '*' while simultaneously declaring credentials: true.

Data Leaked / Threat Vector:
Completely defeats Same-Origin Policy (SOP). An authenticated landlord or tenant visiting an attacker-controlled website can have their ambient session cookie leveraged to make cross-origin requests and exfiltrate tenant records and financial data.

Required Remediation:
Replace dynamic reflection with a strict whitelist of approved domains (e.g., localhost during development and production domain bindings).

[CRITICAL] SEC-05: Untrusted Frontend Tenant ID Assignment & Account Hijacking

CWE: CWE-639 / CWE-284 (IDOR)

Target Endpoint: `POST /api/auth/register`
Source Location: `src/server/index.ts (Lines 412-444)`

Root Cause Analysis:
The RegisterInput Zod schema allows the client to pass an arbitrary integer tenant_id. During registration, the server executes: const finalTenantId = tenant_id ?? matchingTenant?.id ?? null;, blindly trusting user input.

Data Leaked / Threat Vector:
An attacker can register an arbitrary account specifying tenant_id: 1 (or sequentially iterate through IDs). When accessing GET /api/tenant/portal, the backend binds them directly to that tenant, leaking their lease, invoices, and work orders.

Required Remediation:
Completely strip tenant_id from RegisterInput. Tenant linking must occur only via cryptographically verified invite tokens or matching validated email addresses.

[HIGH] SEC-06: Unrestricted Public Self-Registration as Portfolio Landlord

CWE: CWE-269 (Privilege Escalation)

Target Endpoint: `POST /api/auth/register`
Source Location: `src/server/index.ts (Lines 418-424)`

Root Cause Analysis:
Public self-registration accepts role: 'landlord' without invitation, approval, or verification, only checking role !== 'admin'.

Data Leaked / Threat Vector:
Because Nestara AI manages a unified single-portfolio property database, any internet user who registers as a 'landlord' receives instant full administrative read and write privileges over all properties, tenants, leases, and charges.

Required Remediation:
Force public self-registration to default strictly to tenant (or prospective renter). Landlord accounts must be provisioned exclusively by existing administrators.

Section 2: Endpoint Logic Errors & Data Integrity Bugs

[MEDIUM] BUG-01: Missing Start-Date Window Boundary Generating Premature Charges

CWE: CWE-840 (Business Logic Flaw)

Target Endpoint: `POST /api/rent-charges/generate`
Source Location: `src/server/index.ts (Lines 1134-1146)`

Root Cause Analysis:
The generation loop checks if (l.end_date < periodStart) continue; to skip expired leases, but completely omits checking l.start_date.

Data Leaked / Threat Vector:
If a lease begins in November 2026 and an administrator generates charges for September 2026, the endpoint mistakenly issues rent invoices for dates prior to lease inception.

Required Remediation:
Add a start-date boundary check: const periodEnd = `${period}-31`; if (l.start_date > periodEnd) continue;.

[MEDIUM] BUG-02: Orphaned Payment Records via Pre-Validation Database Insertion

CWE: CWE-703 (Improper Integrity Handling)

Target Endpoint: `POST /api/payments`
Source Location: `src/server/index.ts (Lines 1200-1218)`

Root Cause Analysis:
INSERT INTO payments is executed before verifying whether the target charge_id exists in rent_charges.

Data Leaked / Threat Vector:
If an invalid charge ID is supplied, an orphaned payment record is committed to SQLite before the handler terminates with a 404 error, corrupting relational financial integrity.

Required Remediation:
Validate charge existence and query its balance prior to running the insert statement.

[MEDIUM] BUG-03: Silent Demotion of Admin/Landlord Accounts on Tenant Provisioning

CWE: CWE-284 (Improper Access Control)

Target Endpoint: `POST /api/tenants & POST /api/leases`
Source Location: `src/server/index.ts (Lines 934, 1043)`

Root Cause Analysis:
When auto-provisioning tenant logins, the code runs: UPDATE users SET tenant_id = ?, role = 'tenant' WHERE id = ? whenever an existing user email matches.

Data Leaked / Threat Vector:
If an administrator or landlord email is mistakenly entered into a tenant profile, their privileged administrative role is wiped and replaced with tenant privileges.

Required Remediation:
Check existingUser.role and refrain from overwriting roles if the user is already an administrator or landlord.

[MEDIUM] BUG-04: Missing app.onError Exposing Internal Engine Stack Traces

CWE: CWE-209 (Information Disclosure via Error)

Target Endpoint: `Global Server Router`
Source Location: `src/server/index.ts (App Entry Point)`

Root Cause Analysis:
Hono has no registered app.onError handler. Any uncaught SQLite constraint error, database failure, or runtime error bubbles unhandled.

Data Leaked / Threat Vector:
Violates Vibe Coded App Security Rule 12 ('Hide detailed errors'). Raw error messages exposing internal table names, SQL syntax, or stack traces may be returned to clients.

Required Remediation:
Implement app.onError((err, c) => { console.error(err); return c.json({ error: 'An unexpected internal error occurred' }, 500); });.

[LOW] BUG-05: Missing Sliding-Window Rate Limiting on Vector AI Pipelines

CWE: CWE-400 (Uncontrolled Resource Consumption)

Target Endpoint: `POST /api/ai/recommend & POST /api/ai/compare`
Source Location: `src/server/index.ts (Lines 644-709)`

Root Cause Analysis:
The public AI recommendation and property comparison routes execute multi-criteria weighted scoring and cosine similarity matrix math without rate limiting.

Data Leaked / Threat Vector:
Exposes the edge worker isolate to computational exhaustion / Denial of Service (DoS) from automated scrapers submitting high-frequency concurrent payloads.

Required Remediation:
Apply the existing rateLimiter middleware to /api/ai/* (e.g., max 30 requests per minute per IP).

Remediation Action Plan & Engineering Roadmap

Phase 1: Critical Hotfixes (Immediate)
- Update middleware in src/server/index.ts to guard /api/applications, /api/work-orders, and /api/dashboard/summary.
- Remove dynamic wildcard reflection from CORS middleware; bind strictly to authorized hostnames.
- Strip tenant_id from RegisterInput and enforce default role assignment to 'tenant'.

Phase 2: Data Integrity & Reliability Patches (Next Deploy)
- Patch start-date boundary checks in POST /api/rent-charges/generate.
- Ensure POST /api/payments validates charge existence prior to insertion.
- Guard role demotion in tenant account auto-provisioning.
- Add global app.onError handler to suppress server stack trace leakage.

Section 3: Security Policy Checklist Compliance

Audit compliance against the 15 Mandatory Security Standards for Full-Stack Web Applications:

Rule #	Standard	Status	Audit Finding & Verification Evidence
1	Secure API keys	PASS	Zero third-party private API keys exposed or checked into git.
2	Hide .env files	PASS	.env and .env.* are strictly ignored in .gitignore.
3	Never hardcode secrets	WARN	Hardcoded fallback JWT secret in src/server/auth.ts (needs env enforcement).
4	Add authentication	FAIL	Unauthenticated read access permitted on /api/applications and /api/work-orders.
5	Verify permissions server-side	FAIL	Missing server-side permission checks on dashboard and applicant routes.
6	Don't trust frontend user IDs	FAIL	Directly trusts client-supplied tenant_id during account registration.
7	Isolate user data	FAIL	Tenant work orders and applicant PII not isolated from unauthenticated scraping.
8	Lock down database	PASS	SQLite queries use parameterized prepared statements; no SQL injection.
9	Secure Supabase / Storage	N/A	Cloudflare D1 is utilized locally and bound securely.
10	Protect admin routes	FAIL	Self-registration permits public users to escalate themselves to 'landlord'.
11	Disable debug mode	PASS	Production debug flags are not active.
12	Hide detailed errors	WARN	Missing app.onError global boundary; uncaught DB exceptions may leak.
13	Validate inputs server-side	PASS	Zod schemas enforce validation on all major endpoints.
14	Sanitize user content	PASS	LIKE search queries escape special wildcards (% and _).
15	Secure file uploads	N/A	No binary/file upload endpoints currently implemented.

Audit Certification: This document represents an authoritative technical security audit of rootnode-rebels/nestara-ai. Remediation must be validated via regression testing prior to production rollout.